Projet SecureOps

Audit de Sécurité NexaTech

Bootcamp intensif de 5 jours — Mission d'audit de sécurité réelle confiée à un cabinet de conseil cyber par la PME NexaTech, suite à une tentative d'intrusion détectée par l'hébergeur.

16 AVRIL 2026

CLASSIFICATION : CONFIDENTIEL

Made with GAMMA

Scénario d'Audit

Client

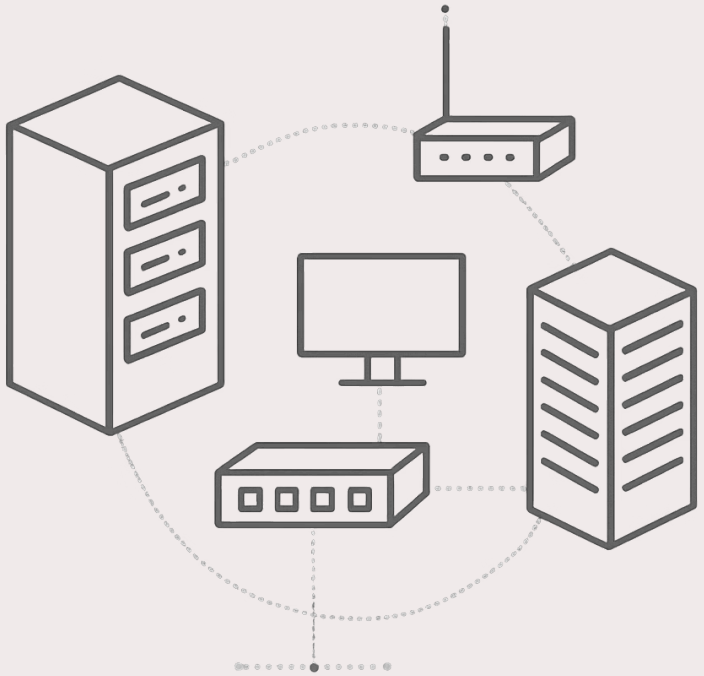
NexaTech — PME de 80 collaborateurs gérant des documents RH sensibles via une application web PHP.

Contexte

Alerte de sécurité de l'hébergeur signalant une tentative d'intrusion. Mission d'audit approfondie mandatée en urgence.

Périmètre

Infrastructure Réseau, Windows Server 2022 AD, Debian Linux Web, Application RH (PHP).



Made with GAMMA

Objectifs de la Mission

1

Audit d'Infrastructure

Analyse de la configuration Windows Server 2022 et du Serveur Debian.

2

Audit Applicatif

Recherche de vulnérabilités OWASP Top 10 sur l'application RH (SQLi, XSS, IDOR).

3

Automatisation

Script d'audit Bash pour assurer une surveillance continue.

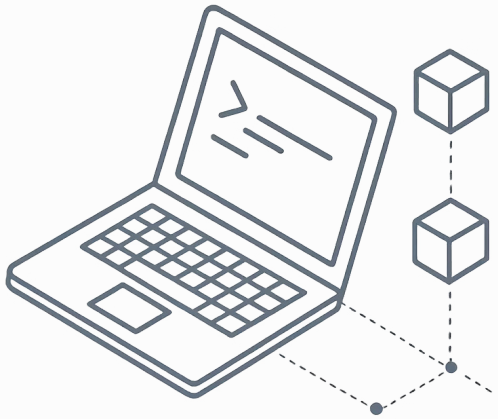
4

Remédiation

Correctifs et bonnes pratiques de durcissement (hardening).

Made with GAMMA

Environnement Technique & Compétences



Technologies

- **Systèmes :** Linux Debian 12, Windows Server 2022
- **Annuaire :** Active Directory
- **Web :** PHP (Application RH)
- **Sécurité :** OWASP (XSS, SQLi, IDOR)
- **Automatisation :** Scripting Bash

Compétences

- Pentesting & exploitation de failles
- Sécurité réseau & durcissement système
- Gestion de crise & réponse à incident
- Rédaction de rapports techniques

Made with GAMMA

Feuille de Route — 5 Jours

1

J1

Cartographie de l'infrastructure + vulnérabilités applicatives

2

J2

Corrections applicatives + hardening serveur Linux

3

J3

Hardening Windows Server + script Bash v1 fonctionnel

4

J4

Rapport d'audit technique détaillé

5

J5

Démonstration PoC et soutenance orale

Made with GAMMA

Résumé Exécutif — Posture Initiale

L'audit a révélé une **posture de sécurité initialement très faible et critique**.

Injection SQL

CVSS **9.8** — Bypass d'authentification via `' OR '1'='1`, compromission totale des données RH.

IDOR

CVSS **8.1** — Contournement d'autorisation par accès direct aux URL sensibles.

Infrastructure

Surface d'attaque excessive : SMBv1 activé, SSH Root accessible, pare-feu inactif.

Made with GAMMA

Audit Applicatif — Portail RH

Vulnérabilité	CVSS	Statut Initial	Statut Final
Injection SQL (SQLi)	9.8 Critique	Actif	Corrigé
Contournement Autorisation (IDOR)	8.1 Haute	Actif	Corrigé
XSS Réfléchi	6.1 Moyenne	Actif	Corrigé
Identifiants de Session Faibles	7.5 Haute	Actif	Corrigé
Fuites d'Information (Bannière)	5.0 Moyenne	Actif	Corrigé

Remédiations : Requêtes préparées PDO, `htmlspecialchars()`, contrôle de session strict, headers de sécurité (`X-Frame-Options`, `X-Content-Type-Options`).

Made with GAMMA

Audit d'Infrastructure

LINUX DEBIAN 12

SSH Root autorisé

CVSS 9.1 — Port déplacé sur **707**, `PermitRootLogin` désactivé, authentification clé Ed25519 uniquement.

Pare-feu UFW inactif

CVSS 7.5 — Activé en mode whitelist (707/tcp, 80/tcp, 443/tcp).

WINDOWS SERVER 2022 AD

SMBv1 & NTLMv1 activés

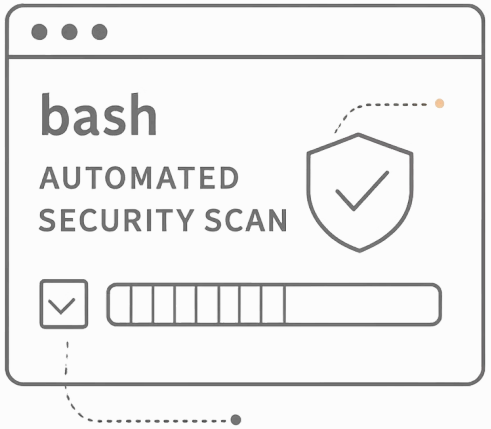
CVSS 8.0–8.4 — SMBv1 désactivé, LM Compatibility Level 5 (NTLMv2 strict).

Politique mot de passe faible

CVSS 7.0 — Minimum **14 caractères**, complexité forcée, 24 mots de passe mémorisés, verrouillage après 5 tentatives / 15 min.

Made with GAMMA

Automatisation & Recommandations



Script Bash `audit_nexatech.sh`

Déployé sur le serveur Linux pour surveillance continue : vérification UFW, port SSH, permissions `/etc/shadow`, binaires SUID suspects. Recommandation : intégration **cron** avec rapport email.

Feuille de Route

- **Haute (1 sem.)** : LAPS (Windows AD), Fail2Ban (Linux)
- **Moyenne (2 sem.)** : Content Security Policy stricte
- **Moyenne (1 mois)** : Audit rotation mot de passe KRBTGT
- **Basse (3 mois)** : Déploiement SIEM (Wazuh / Graylog)

Made with GAMMA

Conclusion — Posture Finale

Le risque immédiat de compromission des données RH est écarté. Le niveau de risque global est passé de **CRITIQUE à MODÉRÉ**.

SSH

Root désactivé, port 707, clé Ed25519 uniquement

Réseau

Pare-feu UFW actif, SMBv1 supprimé, NTLMv2 strict

Applicatif

OWASP Top 10 critiques neutralisées (SQLi, IDOR, XSS)

Monitoring

Scripts Bash déployés, prêts à automatisation cron

Équipe SecureOps : Clarisse DAUDEL (Consultante Cybersécurité) · Maxime CASTEL (Ingénieur Sécurité Systèmes & Réseaux)

Made with GAMMA